

ISO 27001 Reporte de incidente - Vulnerabilidad de Inyección SQL

Introducción

Este reporte argumenta la nueva vulnerabilidad de inyección sql en DVWA. Todas las pruebas se han hecho en un entorno controlado para demostrar con claridad a la comunidad este tipo de vulnerabilidad.

Descripción del incidente

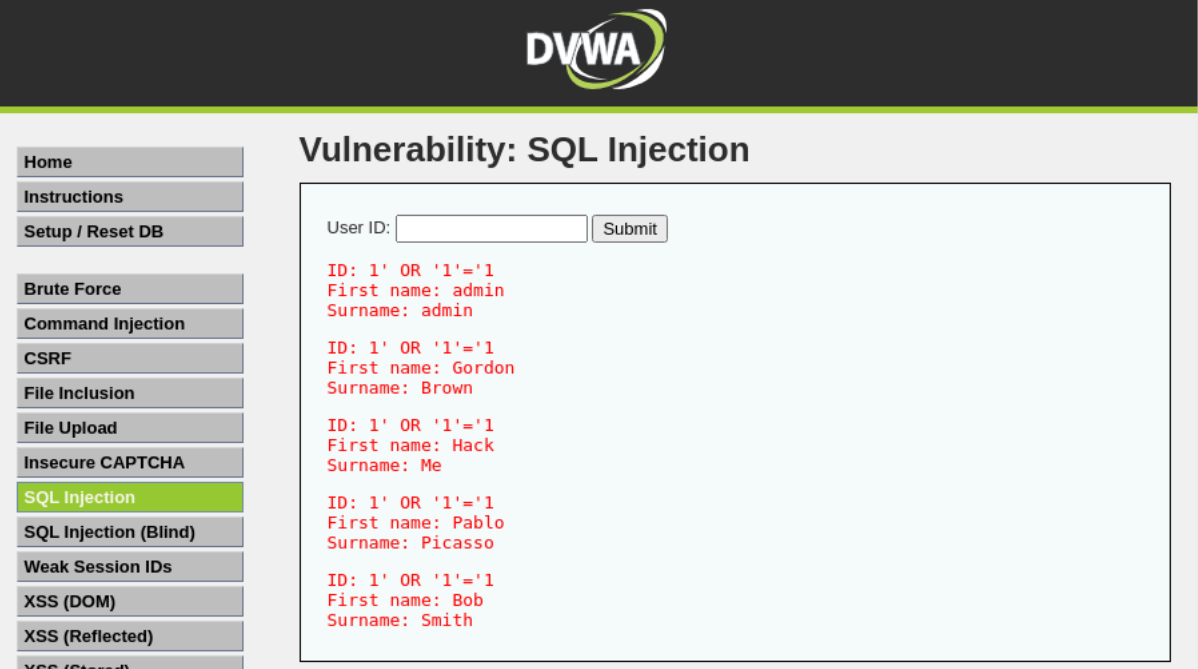
Durante el proceso de securización se ha encontrado el apartado de SQL INJECTION en la configuración de DVWA lo cual permite inyectar código sql malicioso, el cual puede comprometer la integridad y confidencialidad de los datos guardados en la base de datos

Proceso de Reproducción

En el apartado de SQL INJECTION se ha añadido el siguiente código:

```
1' OR '1'='1
```

El cual nos muestra la información de las columnas “nombres y apellidos” de la base de datos.



DVWA

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

Impacto del incidente

Este es un problema de seguridad grave ya que con esta vulnerabilidad activa el atacante puede conocer el contenido de las columnas nombre y apellido de la base de datos, lo cual es información sensible que debería poder ser accesible

Recomendaciones

En primer lugar se tendría que validar los inputs y no dejar poner cualquier caracter, tambien dependiendo de la información de la base de datos sería recomendable no guardarla en texto plano sino cifrada sobre todo si es información sensible.

Conclusión

Si bien este análisis se realizó en un entorno controlado, el impacto potencial en un sistema en producción podría ser devastador, afectando tanto a los usuarios como a la reputación de la organización. Por ello, es fundamental implementar las recomendaciones propuestas, como la validación estricta de los inputs y el uso de cifrado para proteger la información sensible. La adopción de estas medidas mitigará el riesgo asociado a esta vulnerabilidad y contribuirá a un entorno más seguro.